

SecureScan UI · 공통 컴포넌트

FastAPI + Jinja2 + 일반 CSS 구현을 위한 데스크톱 관리 콘솔 시스템

SecureScan

프로젝트

KISA 규칙

사용자 관리

SAST Management Console

저장

취소

제거

처리 중...

프로젝트명

프로젝트명을 입력하세요

대상 언어

Java

전체 Finding

128

아직 프로젝트가 없습니다

새 프로젝트를 생성하면 분석을 시작할 수 있습니다.

사용자를 제거하시겠습니까?

프로젝트 접근 권한이 즉시 해제됩니다. 계정은 삭제되지 않습니다.

취소

제거

항목	상태	작업
데이터 항목	COMPLETED	상세

이전

1

2

다음

PARTIAL

PARTIAL

NOT_IMPLEMENTED

PENDING

프로젝트

김

김관리자

ADMIN

로그아웃

프로젝트

김

김관리자

ADMIN

로그아웃

일관된 콘솔 레이아웃

상단 사용자 정보와 좌측 네비게이션은 모든 관리 화면에서 동일하게 유지됩니다.

CRITICAL

HIGH

MEDIUM

LOW

INFO

COMPLETED

RUNNING

FAILED

HIGH CONFIDENCE

요청을 처리하지 못했습니다. 잠시 후 다시 시도해 주세요.

안전한 코드를 위한 정적 분석 관리 콘솔

프로젝트 소스를 분석하고 KISA 보안 약점을 일관된 기준으로 관리하세요.

- ✓ KISA 기준 취약점 규칙 관리
- ✓ Java · JavaScript · Python 분석
- ✓ 역할 기반 프로젝트 접근 제어

계정 로그인

조직에서 발급받은 계정으로 로그인하세요.

❗ 아이디 또는 비밀번호가 올바르지 않습니다.

아이디

아이디를 입력하세요

비밀번호

.....

로그인

로딩 및 버튼 비활성화 상태

로그인 중...

프로젝트 목록

소스 분석 대상과 최근 실행 상태를 관리합니다.

+ 프로젝트 생성

프로젝트명 또는 설명 검색

총 12개 프로젝트

프로젝트명	설명	언어	최근 상태	최근 분석 시각	작업
금융 API Gateway	결제·인증 API 보안 약점 분석	Java	COMPLETED	2025-02-18 14:32	상세 →
고객 포털	외부 고객용 웹 애플리케이션	JavaScript	RUNNING	2025-02-18 13:05	상세 →
데이터 파이프라인	내부 배치 및 ETL 서비스	Python	FAILED	2025-02-17 09:41	상세 →
관리자 콘솔	사내 운영 관리 화면	JavaScript	COMPLETED	2025-02-16 18:20	상세 →
1-4 / 12				이전	12다음

ADMIN은 프로젝트를 생성·수정하고 사용자를 할당할 수 있습니다.

프로젝트 목록

소스 분석 대상과 최근 실행 상태를 관리합니다.

 프로젝트명 또는 설명 검색

총 0개 프로젝트



할당된 프로젝트가 없습니다

프로젝트 ADMIN에게 접근 권한 할당을 요청하세요.

 USER는 할당된 프로젝트의 분석 결과를 조회할 수 있습니다.

프로젝트 생성

분석할 소스의 기본 정보를 입력합니다. 동일한 폼이 수정 화면에도 사용됩니다.

프로젝트명 *

프로젝트명을 입력하세요

❗ 프로젝트명은 필수 입력 항목입니다.

설명

프로젝트 목적과 분석 범위를 입력하세요

대상 언어 *

소스 유형

Java

ZIP

📘 지원 언어: Java, JavaScript, Python · 소스 파일은 프로젝트 상세에서 ZIP으로 업로드합니다.

취소

저장

생성/수정 공통 템플릿

* 필수 입력

프로젝트 > 금융 API Gateway

금융 API Gateway

프로젝트 수정

개요소스 및 분석사용자 관리

프로젝트 기본 정보

설명	결제·인증 API의 보안 약점 분석
대상 언어	Java
소스 유형	ZIP
생성일	2025-01-12
최근 수정	김관리자 · 2025-02-18

최근 분석 상태

COMPLETED

2025-02-18 14:32

실행자 김관리자 · Engine 1.8.2

결과 보기 →

최근 분석 요약

Critical 3	High 12	Medium 28	Low 41
---------------	------------	--------------	-----------

최근 분석 이력전체 이력 보기 →

AN-20250218-042	김관리자	2025-02-18 14:32	COMPLETED
AN-20250216-038	이사용자	2025-02-16 18:20	FAILED

금융 API Gateway

프로젝트 수정

개요

소스 및 분석

사용자 관리

ZIP 소스 업로드



ZIP 파일을 끌어놓거나 파일을 선택하세요

파일 선택



gateway-api-v2.4.1.zip

18.4 MB · 선택 완료



분석 실행

업로드 제한

ZIP 파일 최대 크기

20 MiB

압축 해제 후 전체 크기

최대 100 MiB

압축 파일 크기와 압축 해제 후 크기에 각각 적용되는 별도 제한입니다.



업로드 소스는 분석 목적으로만 저장됩니다.

최근 분석 이력

전체 이력 보기 →

AN-20250219-043

김관리자

2025-02-19 10:12

RUNNING

AN-20250218-042

김관리자

2025-02-18 14:32

COMPLETED

프로젝트 > 금융 API Gateway

금융 API Gateway

프로젝트 수정

개요

소스 및 분석

사용자 관리

할당된 사용자

프로젝트 접근 권한과 역할을 관리합니다.

+ 사용자 추가

사용자명	전역 역할	활성 상태	작업
김관리자	ADMIN	활성	제거
이사용자	USER	활성	제거
박감사	USER	활성	제거



ADMIN 전용 관리

ADMIN은 프로젝트 사용자 소속을 추가하거나 제거 할 수 있습니다. 표시되는 역할은 계정의 전역 역할 인 ADMIN 또는 USER입니다.

사용자 제거는 프로젝트 접근 권한만 해제하며 계정을 삭제하지 않습니다.

프로젝트 > 금융 API Gateway

금융 API Gateway

- 개요
- 소스 및 분석
- 사용자 관리



접근 권한이 없습니다

사용자 관리 탭은 ADMIN만 수정할 수 있습니다. 프로젝트 개요와 분석 결과는 계속 조회할 수 있습니다.

개요로 돌아가기

분석 이력 및 실행 상태

금융 API Gateway의 분석 실행 기록과 결과를 확인합니다.

새 분석 실행

상태

실행자 검색

전체 상태

사용자명 검색

분석 ID	실행자	언어	엔진	시작 시각	종료 시각	상태	결과
AN-20250219-043	김관리자	Java	1.8.2	02-19 10:12	—	RUNNING	결과 보기
AN-20250218-042	김관리자	Java	1.8.2	02-18 14:32	02-18 14:38	COMPLETED	결과 보기
AN-20250216-038	이사용자	Java	1.8.1	02-16 18:20	02-16 18:22	FAILED	결과 보기
AN-20250214-031	박감사	Java	1.8.1	02-14 09:05	02-14 09:11	COMPLETED	결과 보기
AN-20250212-027	김관리자	Java	1.8.0	02-12 16:42	—	PENDING	결과 보기
1-5 / 27							이전12다음

분석 실행

AN-20250219-043 · 금융 API Gateway



분석을 실행하고 있습니다.

분석이 끝날 때까지 페이지를 닫지 마세요.



분석 완료 후 결과 화면으로 이동합니다.

분석을 완료하지 못했습니다

AN-20250216-038 · 금융 API Gateway

FAILED



ZIP 파일의 일부 소스를 읽을 수 없습니다

업로드한 압축 파일에 암호화되거나 손상된 항목이 포함되어 분석이 중단되었습니다. 파일을 다시 압축한 후 재시도해 주세요.

참조 코드 **SOURCE_ARCHIVE_READ_FAILED**

재시도 전 확인 사항

- ✓

 ZIP 파일이 암호화되지 않았는지 확인
- ✓

 압축 해제 시 오류가 없는지 확인
- ✓

 최대 업로드 크기 20 MiB 확인

실행 정보

시작 시각	2025-02-16 18:20
실패 시각	2025-02-16 18:22
실행자	이사용자
엔진	1.8.1

분석 이력으로

파일 교체 후 재실행

Finding 목록

AN-20250218-042 · 금융 API Gateway 분석 결과

분석 이력

전체 Finding

84

Critical

3

High

12

Medium

28

Low

41

Severity

전체

Confidence

전체

검색

규칙명, KISA ID, 파일 경로 검색

규칙명	KISA ID	Severity	Confidence	파일 경로	코드 위치	상세
하드코드된 인증정보	제2절-6	CRITICAL	HIGH	src/main/ ... /TokenService.java	42:15	상세 보기
SQL 삽입 가능성	제1절-1	HIGH	HIGH	src/main/ ... /UserRepository.java	118:9	상세 보기
부적절한 예외 처리	제3절-1	MEDIUM	MEDIUM	src/main/ ... /PaymentService.java	76:5	상세 보기
약한 암호화 알고리즘	제2절-4	HIGH	HIGH	src/main/ ... /CryptoUtil.java	31:12	상세 보기
불필요한 정보 노출	제3절-2	LOW	MEDIUM	src/main/ ... /ErrorHandler.java	54:7	상세 보기
1-5 / 84					이전	12다음

Finding 목록

AN-20250220-044 · 고객 포털 분석 결과

전체 Finding 0	Critical 0	High 0	Medium 0	Low 0
-----------------	---------------	-----------	-------------	----------



탐지된 보안 약점이 없습니다

선택한 분석에서 KISA 규칙에 해당하는 Finding이 발견되지 않았습니다.

분석 이력 확인

[← Finding 목록으로 돌아가기](#)

하드코드된 인증정보

제2절-6 CRITICAL HIGH CONFIDENCE

AN-20250218-042

탐지 메시지

소스 코드에 인증 토큰으로 추정되는 문자열이 직접 선언되어 있습니다. 저장소 노출 시 외부 사용자가 인증정보를 획득할 수 있습니다.

src/main/java/auth/TokenService.java42:15-42:48

```
39 public class TokenService {
40     private final JwtDecoder decoder;
41
42     private static final String API_TOKEN = "sk_live_9f2...";
43
44     public Token issue(User user) {
45         return signer.sign(user, API_TOKEN);
46     }
```

탐지 근거

문자열 리터럴이 토큰 명명 패턴과 고엔트로피 값 조건을 동시에 충족했습니다.

조치 권고

인증정보를 환경 변수 또는 조직의 비밀 관리 시스템으로 이전하고 노출된 토큰을 즉시 폐기하세요.

원본 분석 결과 확인



탐지 정보

대상 언어
Java

파일 경로
src/main/java/auth/TokenService.java

시작 위치
42:15

종료 위치
42:48

분석 엔진
Semgrep 1.8.2

탐지 시각
2025-02-18 14:36

KISA 규칙 카탈로그

소프트웨어 개발보안 가이드 기준 49개 항목의 구현 현황을 확인합니다.

TOTAL 49

검색

규칙 ID 또는 규칙명 검색

카테고리

전체 카테고리

구현 상태

전체 상태

규칙 ID	규칙명	카테고리	Severity	구현 상태	언어 지원	Semgrep
제2절-6	하드코드된 인증정보	입력데이터 검증	CRITICAL	PARTIAL	J · JS · PY	연결
제1절-1	SQL 삽입	입력데이터 검증	HIGH	PARTIAL	J · PY	연결
제2절-4	취약한 암호화	보안기능	HIGH	PARTIAL	J · JS · PY	연결
제3절-1	부적절한 예외 처리	에러 처리	MEDIUM	PARTIAL	J · PY	연결
제3절-2	정보 노출	에러 처리	LOW	NOT_IMPLEMENTED	J · JS	미연결
제1절-2	경쟁 조건	시간·상태	MEDIUM	NOT_IMPLEMENTED	—	미연결
제2절-1	부적절한 권한 검사	접근 통제	CRITICAL	PARTIAL	J · PY	연결
1-7 / 49					이전	12다음

선택한 규칙

제2절-6

하드코드된 인증정보

인증정보가 소스 코드에 직접 기록되어 외부에 노출될 수 있는 취약점을 탐지합니다.

카테고리

입력데이터 검증 및 표현

기본 Severity

CRITICAL

구현 상태

PARTIAL

Semgrep Rule

kisa.hardcoded-credential

Java

JavaScript

Python

사용자 관리

계정 역할과 활성 상태를 관리합니다. 계정은 물리적으로 삭제하지 않습니다.

사용자 검색

사용자명 검색

총 24명 · 활성 22명

사용자명	역할	활성 상태	관리 작업		
김관리자	ADMIN	활성	수정	비활성화 불가	비밀번호 초기화
이사용자	USER	활성	수정	비활성화	비밀번호 초기화
박감사	USER	활성	수정	비활성화	비밀번호 초기화
최개발	USER	활성	수정	비활성화	비밀번호 초기화
정퇴사	USER	비활성	수정	활성화	비밀번호 초기화
시스템관리	ADMIN	활성	수정	비활성화	비밀번호 초기화
1-6 / 24			이전	1	2 다음

사용자 수정

이이사용자

역할

USER

계정 활성 상태

비활성화 시 로그인 이 차단됩니다.



비밀번호 초기화

새 비밀번호

.....

새 비밀번호 확인

.....

비밀번호 저장

취소

변경 저장

분석 이력 및 실행 상태

고객 포털 프로젝트의 분석 기록입니다.

첫 분석 실행



아직 실행한 분석이 없습니다

ZIP 소스를 업로드하고 첫 번째 정적 분석을 실행하세요.

사용자 생성

username *

username을 입력하세요

ⓘ 사용자명은 필수 입력 항목입니다.

password *

.....

역할 *

USER

password 확인 *

.....

활성 상태

활성 상태로 계정을 생성합니다.

취소

사용자 생성



사용자 정보를 불러오지 못했습니다

일시적인 서버 오류가 발생했습니다. 입력한 내용은 변경되지 않았습니다. 잠시 후 다시 시도해 주세요.

오류 참조 **USR-500-7F21**

프로젝트로 이동

다시 시도

진단 항목 등록

KISA 카탈로그 항목과 배포된 Semgrep rule ID를 연결합니다.

진단 항목 정보

KISA 카탈로그 항목 *

KISA ID · 분류 · 항목 번호 · 명칭으로 검색

진단 항목명 *

진단 항목명을 입력하세요

설명

탐지 목적과 적용 범위를 입력하세요

참조 정보 또는 공식 문서 링크

https://...

기본 심각도 *

HIGH

구현 상태 *

IMPLEMENTED

활성 여부

활성 항목만 분석 실행에 사용됩니다.



지원 언어 *



Java



JavaScript



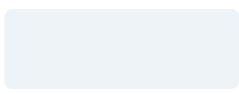
Python

언어별 Semgrep rule ID



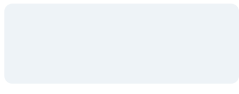
Java

kisa-2021-sql-injection-java



JavaScript

kisa-2021-sql-injection-javascript



Python

kisa-2021-sql-injection-python



Semgrep YAML은 검토 후 별도 배포하며 이 화면에서는 실행 코드를 입력하지 않습니다.

ADMIN

목록으로 돌아가기

상태 예시

필수값 누락

진단 항목명은 필수 입력 항목입니다.

중복 Semgrep rule ID

동일한 rule ID가 이미 등록되어 있습니다.

언어 rule ID 누락

JavaScript를 선택했지만 rule ID가 없습니다.

✓ 진단 항목이 등록되었습니다.

접근 권한 없음

이 기능은 ADMIN만 사용할 수 있습니다.

취소

진단 항목 등록

진단 항목 수정

현재 등록된 진단 항목의 메타데이터와 rule ID를 수정합니다.

진단 항목 정보

KISA 카탈로그 항목 · 읽기 전용

KISA ID

분류

항목 번호

명칭

제1절-1

입력데이터 검증

04

SQL 삽입

진단 항목명 *

SQL 삽입 탐지

설명

사용자 입력값에 포함된 SQL 구문을 검증합니다.

참조 정보 또는 공식 문서 링크

https://www.kisa.or.kr/guide/sql-injection

기본 심각도 *

HIGH

구현 상태 *

IMPLEMENTED

활성 여부

비활성 항목은 분석 실행에서 제외됩니다.



지원 언어

☒ Java

☒ JavaScript

☒ Python

언어별 Semgrep rule ID

Java kisa-2021-sql-injection-java

JavaScript kisa-2021-sql-injection-javascript

Python kisa-2021-sql-injection-python

취소

비활성화

변경 저장

ADMIN

목록으로 돌아가기

참조 Finding

12

마지막 수정

2025-02-21

 이 항목은 비활성화되면 분석 대상에서 제외됩니다.

검증 상태

☒ PARTIAL

☐ PARTIAL

☐ NOT_IMPLEMENTED

USER 접근 권한 없음

진단 항목 등록·수정은 ADMIN 전용 기능입니다.

KISA 개발보안 진단 기준

KISA 소프트웨어 보안약점 진단가이드(2021) 구현단계 49개 항목

ADMIN+ 진단 항목 등록

전체49	IMPLEMENTED0	PARTIAL4	NOT_IMPLEMENTED45
------	--------------	----------	-------------------

검색

분류

구현 상태

지원 언어

활성 여부

KISA ID 또는 명칭 검색

전체 분류

전체 상태

전체 언어

활성

KISA ID	분류	항목 번호	명칭	기본 심각도	구현 상태	지원 언어	활성 상태	상세
제2절-6	보안기능	6	하드코딩된 중요정보	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →
제1절-1	입력데이터 검증	1	SQL 삽입	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →
제2절-4	보안기능	4	취약한 암호화 알고리즘 사용	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →
제3절-1	에러 처리	17	부적절한 예외 처리	MEDIUM	NOT_IMPLEMENTED	Java · Python	활성	상세 보기 →
제3절-2	에러 처리	22	정보 노출	LOW	PARTIAL	Java · JavaScript	활성	상세 보기 →
제4절-1	시간-상태	1	경쟁 조건	MEDIUM	NOT_IMPLEMENTED	—	비활성	상세 보기 →
1-6 / 49							이전	12다음

SQL 삽입

제1절-1

HIGH

PARTIAL

ADMIN

진단 항목 수정

설명

사용자 입력값에 포함된 SQL 구문을 검증하지 않으면 데이터베이스 명령이 변조될 수 있는 보안약점입니다.

조치 권고

사용자 입력값을 명시적으로 검증하고 매개변수화된 쿼리 또는 안전한 ORM API를 사용하세요.

참조 정보

KISA 소프트웨어 보안약점 진단가이드(2021) · 공식 진단 기준 제1절-1

지원 언어와 언어별 Semgrep rule ID

Java

kisa-2021-sql-injection-java

Python

kisa-2021-sql-injection-python

JavaScript

kisa-2021-sql-injection-javascript

항목 메타데이터

KISA ID

제1절-1

분류

입력데이터 검증

항목 번호

04

기본 심각도

HIGH

구현 상태

PARTIAL

활성 여부

활성

현재 활성 항목

현재 분석 실행에 적용되고 있습니다.

연결된 최근 Finding

12건

KISA 개발보안 진단 기준

KISA 소프트웨어 보안약점 진단가이드(2021) 구현단계 49개 항목

전체 49	IMPLEMENTED 0	PARTIAL 4	NOT_IMPLEMENTED 45
----------	------------------	--------------	-----------------------

검색

분류

구현 상태

지원 언어

활성 여부

KISA ID 또는 명칭 검색

전체 분류

전체 상태

전체 언어

활성

KISA ID	분류	항목 번호	명칭	기본 심각도	구현 상태	지원 언어	활성 상태	상세		
제2절-6	보안기능	6	하드코딩된 중요정보	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →		
제1절-1	입력데이터 검증	1	SQL 삽입	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →		
제2절-4	보안기능	4	취약한 암호화 알고리즘 사용	HIGH	PARTIAL	Java · JavaScript · Python	활성	상세 보기 →		
제3절-1	에러 처리	17	부적절한 예외 처리	MEDIUM	NOT_IMPLEMENTED	Java · Python	활성	상세 보기 →		
제3절-2	에러 처리	22	정보 노출	LOW	NOT_IMPLEMENTED	Java · JavaScript	활성	상세 보기 →		
제4절-1	시간-상태	1	경쟁 조건	MEDIUM	NOT_IMPLEMENTED	—	비활성	상세 보기 →		
1-6 / 49							이전	1	2	다음

읽기 전용 · 진단 항목 등록 및 수정은 ADMIN 전용입니다.

KISA 규칙 > 제1절-1

SQL 삽입

제1절-1

HIGH

PARTIAL

읽기 전용 · 카탈로그 조회만 가능합니다.

설명

사용자 입력값에 포함된 SQL 구문을 검증하지 않으면 데이터베이스 명령이 변조될 수 있는 보안약점입니다.

조치 권고

사용자 입력값을 명시적으로 검증하고 매개변수화된 쿼리 또는 안전한 ORM API를 사용하세요.

참조 정보

KISA 소프트웨어 보안약점 진단가이드(2021) · 공식 진단 기준 제1절-1

지원 언어와 언어별 Semgrep rule ID

Java	kisa-2021-sql-injection-java
Python	kisa-2021-sql-injection-python
JavaScript	kisa-2021-sql-injection-javascript

연결된 최근 Finding

12건

항목 메타데이터

KISA ID	제1절-1
분류	입력데이터 검증
항목 번호	04
기본 심각도	HIGH
구현 상태	PARTIAL
활성 여부	활성

현재 활성 항목

현재 분석 실행에 적용되고 있습니다.

코드삽입

제1절-2 HIGH

ADMIN

진단 항목 수정

설명

소스 코드에 실행 가능한 명령이 삽입되어 의도하지 않은 동작이 발생할 수 있는 보안약점입니다.

조치 권고

외부 입력을 검증하고 실행 가능한 코드가 삽입되지 않도록 안전한 API와 출력 인코딩을 적용하세요.

참조 정보

KISA 소프트웨어 보안약점 진단가이드(2021) · 코드삽입 기준 제1절-2

지원 언어와 언어별 Semgrep rule ID

지원 언어: 미지원

Semgrep rule ID: 등록되지 않음

항목 메타데이터

KISA ID	제1절-2
분류	입력데이터 검증
항목 번호	2
기본 심각도	HIGH
구현 상태	NOT_IMPLEMENTED
활성 여부	활성

NOT_IMPLEMENTED

현재 등록된 Semgrep rule ID가 없어 분석에 사용되지 않습니다.

연결된 최근 Finding 0건

코드삽입

제1절-2HIGHNOT_IMPLEMENTED

ADMIN진단 항목 수정

설명

소스 코드에 실행 가능한 명령이 삽입되어 의도하지 않은 동작이 발생할 수 있는 보안약점입니다.

조치 권고

외부 입력을 검증하고 실행 가능한 코드가 삽입되지 않도록 안전한 API와 출력 인코딩을 적용하세요.

참조 정보

KISA 소프트웨어 보안약점 진단가이드(2021) · 코드삽입 기준 제1절-2

지원 언어와 언어별 Semgrep rule ID

지원 언어: 미지원

Semgrep rule ID: 등록되지 않음

연결된 최근 Finding0건

항목 메타데이터

KISA ID제1절-2

분류입력데이터 검증

항목 번호2

기본 심각도HIGH

구현 상태NOT_IMPLEMENTED

활성 여부비활성

비활성 항목

비활성 항목은 신규 분석에 사용되지 않으며 분석 결과에 반영되지 않습니다.

KISA 개발보안 진단 기준

KISA 소프트웨어 보안약점 진단가이드(2021) 구현단계 49개 항목



존재하지 않는 규칙



검색 결과가 없습니다

KISA ID 또는 명칭을 확인하고 다시 검색해 주세요.

검색 초기화



카탈로그를 불러오지 못했습니다

일시적인 서버 오류가 발생했습니다. 잠시 후 다시 시도해 주세요.

다시 시도